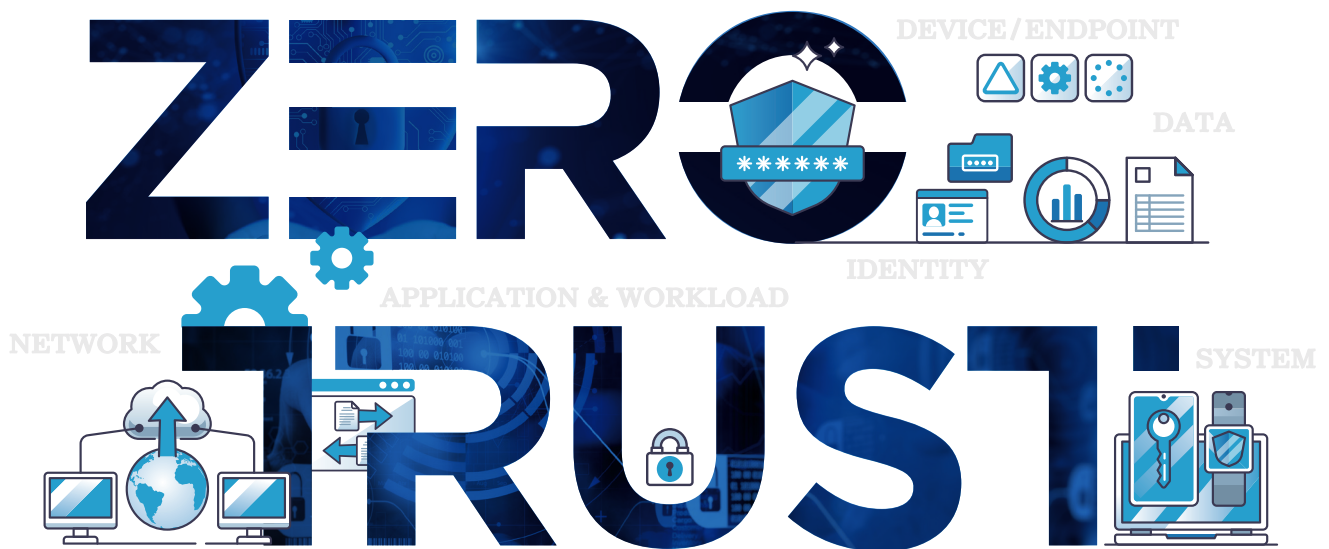


제로트러스트

가이드라인 2.0

2024. 12.



제로트러스트 가이드라인 2.0

2024. 12.



제로트러스트 가이드라인 2.0

제1장

제로트러스트 가이드라인 2.0 개요



제2장

제로트러스트 보안 모델 및 도입 필요성



제3장

제로트러스트 성숙도 모델 및 세부역량



제4장

제로트러스트 도입 준비 방안



제5장

제로트러스트 도입 수준 분석



부록



제1절 가이드라인 2.0 발간 배경	8
제2절 가이드라인 2.0 목적 및 구성	14
제3절 가이드라인 2.0 주안점	17

제1절 제로트러스트 아키텍처 보안 모델	22
제2절 기업은 왜 제로트러스트를 도입해야 하는가?	28

제1절 제로트러스트 성숙도 모델 2.0	35
제2절 제로트러스트 성숙도 모델 기반 보안 세부역량	51
제3절 제로트러스트 성숙도 모델 기반 구현 방안	90

제1절 제로트러스트 아키텍처 도입 고려사항	106
제2절 제로트러스트 아키텍처 도입을 위한 조직 내 역할 및 목표 설정	120
제3절 제로트러스트 아키텍처 구성 방안	128
제4절 제로트러스트 아키텍처 도입 준비 예시	139

제1절 제로트러스트 성숙도 기반 도입 수준 분석	150
제2절 제로트러스트 침투 시험 기반 효과성 분석	170

제1절 용어 및 약어 정의	184
제2절 국내 기업 제로트러스트 인식 수준	194
제3절 제로트러스트 아키텍처 참조 모델 실증 사례	202
제4절 미 연방정부 제로트러스트 도입·실증 현황	216
제5절 성숙도 모델 개념	229
제6절 ISMS-P 인증기준과 제로트러스트 성숙도 모델 연계	234
제7절 참고 문헌	240

최근 급변하는 디지털 전환기에서 AI의 진화, 클라우드 서비스 보편화 등 혁신적 기술들은 계속 등장하고 새로운 서비스와 가치를 창출하고 있습니다. 하지만, 악의적인 공격자들은 끊임없이 진화하여 다양한 신기술을 활용한 새로운 공격 방식을 통해 기업을 위협하고 있습니다. 사이버 위협은 기업의 지속 가능성을 위협하는 중대한 리스크이므로 기업은 사이버보안 강화를 경영 전략의 핵심 요소로 고려할 필요가 있으며 기업이 보유한 자산을 지키기 위해 방어 전략 및 체계 역시 진화가 시급한 상황입니다. 이러한 가운데 급부상하고 있는 제로트러스트는 기업의 사이버 위협 대응의 체질 개선을 위해 필수적으로 도입해야 하는 도전 과제라고 할 수 있습니다.

2023년 7월 과학기술정보통신부와 한국인터넷진흥원, 한국제로트러스트포럼의 공동 작업으로 '제로트러스트 가이드라인 1.0'을 발표했습니다. 가이드라인은 우리 기업들의 디지털 업무 환경 안전 체계를 제로트러스트로 이행하는 긴 여정의 첫 발걸음을 내딛는 과정이었습니다. 실제로 공공·민간의 많은 분야에서 가이드라인이 활용되었고 제로트러스트의 철학을 공유하고 기본적인 이해를 하는 데 도움이 됐다는 평이 주를 이루었습니다. 하지만, 한편으로 가이드라인이 제로트러스트 도입을 고려하는 기업의 입장에서 충분한 수준으로 작성을 한 것일까에 대한 걱정도 일부 있었습니다. 각 분야의 전문가들께서는 가이드라인에 대한 격려의 말씀과 함께 가감 없는 현실적인 조언을 전해주셨습니다. 이러한 다양한 의견은 제로트러스트 정책 방향성을 결정하는 데 많은 도움이 되었습니다.

제로트러스트 가이드라인 1.0이 나온 지도 벌써 1년 이상 지났습니다. 그 사이에 글로벌 제로트러스트 정책을 선도하는 미국은 많은 변화가 있었습니다. 연방정부의 각 기관은 대통령 안보 각서에 따라 OMB(관리에산실)에 제로트러스트의 도입과 요구 사항을 충실히 이행하였으며, 주 정부와 지방 행정 기관도 제로트러스트의 도입을 추진하는 등 제로트러스트를 더 이상 이상적인 개념이 아닌 현실에서 구현하기 위한 실체적인 움직임을 보이고 있습니다.

우리나라는 2023년 과학기술정보통신부와 한국인터넷진흥원이 국내 제로트러스트 실증 사업을 성공적으로 진행한 바 있으며, 2024년 시범사업을 연이어 추진함으로써 다양한 도입 사례 확보를 통해 제로트러스트 보안 모델 확산을 위해 노력하고 있습니다. 또한 공공, 금융, 군 등에서도 공공 데이터 활용, 혁신적 AI·클라우드 서비스의 도입, 유연한 근무 방식, 개발 환경 개선 등을 위하여 획일적인 보안 체계와 규정을 보완 하는 등 우리 사회 각 분야의 제로트러스트 보안 체계 전환의 공감대는 증가하고 있습니다.

2024년 5월 과학기술정보통신부와 한국인터넷진흥원 및 한국제로트러스트포럼 정책·제도분과 소속 산학연관 전문가들은 연구반을 구성하여 보안 담당자들의 어려움을 조금이라도 해소할 수 있는 새로운 가이드라인 발간을 기획했습니다. 연구반에서는 지난 수개월 동안 회의와 토론, 수정을 거쳤으며 그 결과물로 제로트러스트 성숙도 모델을 세부 역량 수준으로 상세히 기술하고, 제로트러스트 도입 과정과 도입 수준 분석 방안을 구체화하는 형태의 가이드라인 2.0이 완성하게 되었습니다.

가이드라인 2.0은 제로트러스트의 철학이 기업의 문화에 뿌리를 내릴 수 있도록 최고경영자와 정보보호 최고책임자, 실무자들이 반드시 읽어야 할 항목들을 정의하였으며, 기업의 구성원들이 적극적으로 제로트러스트 이행 과정에서 각자의 역할을 수행할 수 있는 기반을 제공하고자 합니다. 국내 기업들이 전사적으로 제로트러스트를 도입함으로써 위험을 완화하고 보안 수준을 향상한다면, 각 산업 분야에서 더욱 경쟁력을 갖춘 강력한 기업으로 성장하는 밑거름이 될 수 있을 것으로 생각합니다. 앞으로 본 가이드라인 2.0이 기업의 제로트러스트 도입 과정에서 도움이 될 수 있기를 기대하며, 많은 의견과 관심을 부탁드립니다.



제로트러스트
가이드라인 2.0



제1장

제로트러스트 가이드라인 2.0 개요

- | 제1절 | 가이드라인 2.0 발간 배경
- | 제2절 | 가이드라인 2.0 목적 및 구성
- | 제3절 | 가이드라인 2.0 주안점

| 제1절 |

가이드라인 2.0 발간 배경

1. 제로트러스트 보안 체계 전환의 필요성

2010년 미국의 연구기관 포레스터 리서치(Forrester Research)의 수석 애널리스트 존 킨더백(John Kindervag)은 제로트러스트라는 기업망 보안에 대한 기존의 경계 보안 체계와는 차별화된 새로운 탈경계화 기반의 접근 방법론을 제시하였다.

기업¹들이 그동안 기업망²에 구축해 왔던 네트워크 보안 모델은 업무 공간에서 발생할 수 있는 기업 자산 탈취, 파괴, 조작 등 외부의 물리적인 공격에 대응하기 위한 전략과 유사하다고 볼 수 있다. 일반적인 기업의 업무 공간은 외부와 물리적인 경계가 형성되어 있으며, 단일 혹은 다수의 출입문을 통해 내·외부자의 진입과 이동을 통제하고 있다. 그러나, 출입 통제 시스템만으로는 모든 종류의 침투에 대응하기 어려울 뿐 아니라, 정상적인 출입 통제 절차를 지키거나 우회하여 들어온 침입자가 업무 공간 내부의 기업 자산을 탈취, 파괴하는 모든 행위를 막을 수는 없을 것이다.

따라서, 이를 감시·대처하기 위하여 업무 공간의 각 경계 구간에 별도 출입 통제 장치를 둬으로써 공격자가 권한이 없는 공간에 접근할 수 없도록 조치하거나(Micro-Segmentation), CCTV를 설치하여 수상한 행위에 대해 감시하고(Visibility & Analytics), 중요 자산은 금고에 보관함으로써 추가적인 권한 혹은 인증 수단(Multi-Factor Authentication)을 가지고 있어야 접근할 수 있도록

1 본 가이드라인에서의 '기업'은 일반적인 사기업 및 민간 비영리 조직 등 국내 민간 분야의 중·대규모 조직을 통칭하여 표현한다. 본 가이드라인은 제로트러스트의 도입에 대한 정보를 제공하는 것이 목적으로, 정부 및 공공, 군 분야 혹은 민간 분야에 속하더라도 금융 혹은 주요정보통신기반시설 등 별도의 법령 및 규정을 준수해야 하는 기업·기관은 본 가이드라인을 단순 정보 습득을 위하여 활용할 수 있으나 각 분야별 별도의 제로트러스트 도입 지침 혹은 규정이 나올 경우 그 지침 및 규정을 준수하는 것이 우선임을 밝힌다.

2 본 가이드라인에서의 '기업망'은 'Enterprise Network'를 번역하여 사용하고 있는 단어로, 일반적으로 'Enterprise Network'는 중·대규모 조직에서 사용자와 기기, 애플리케이션 프로그램 간 연결을 제공하는 IT 인프라 및 네트워크 시스템을 의미한다. 제로트러스트 보안 철학이 적용되어야 할 중·대규모 조직은 기업뿐만 아니라 민간 비영리 조직 등 역시 해당된다. 따라서, 본 문서 내에서 기업망으로 표현되어 있다 하더라도 명시적으로 기업에서 운용하는 망을 의미하는 것이 아니라면, 기업뿐만 아니라 민간 영역에서의 비영리 기관 등에서 운용하는 네트워크 및 정보시스템을 모두 포괄하는 것으로 이해하는 것이 바람직하다.

조치하기도 한다. 이는 기업 업무 공간 역시 기업 외부와 마찬가지로 더 이상 신뢰할 수 있는 공간이 아니며, 내부에서도 공격자가 존재할 수 있다는 어찌면 당연하다고 할 수 있는 기본적인 보안의 철학이 반영된 결과라고 할 수 있다.

하지만 물리적인 업무 공간과 다르게 네트워크 영역에서는 이러한 접근통제가 지켜지지 않는 경우가 많다. 경계 기반의 보안 체계를 운영하는 상당수 기업의 내부 인가된 사용자는 네트워크만 연결되어 있다면 폭넓은 권한을 통해 시스템 리소스에 언제든지 접근(Access)할 수 있는 것이 현실이다. 이것은 기업의 복잡한 업무 환경의 특성과 구성원의 업무 처리 절차의 신속성, 편의성 확보 등의 다양한 요인이 작용한다. 이러한 내부자 신뢰를 전제로 하는 접근통제 정책의 문제는 내부자의 계정 탈취 또는 내부자에 의한 악성 행위에 대한 안전장치가 없다는 것이다.

최근 다양한 디지털 신기술의 등장으로 사이버 공격의 형태가 고도화·은밀화되고 네트워크의 복잡성 및 관리 포인트가 급격히 증가하는 현 상황은 기업의 운영자와 보안 담당자에게 안전한 네트워크 운영을 위한 많은 고민과 숙제를 안겨 준다. 제로트러스트는 각 네트워크 경계에 있는 진입점을 드나드는 패킷을 감시함으로써 공격 여부를 판단하기보다 리소스 보호에 중점을 두고 사용자 및 접속 기기가 어떤 형태로든 적극적으로 통제하는 개념으로 그동안 보안 분야의 문제를 해결할 수 있는 새로운 방향성을 제시하고 있다. 따라서 근본적인 보안 체계의 체질 개선을 위해 제로트러스트 보안 체계 전환은 필연적이라고 할 수 있으며 이는 보안 산업 분야에서 새로운 기획의 장이 될 수 있을 것이다.

2. 제로트러스트 구현 노력

미국은 제로트러스트 도입에 가장 적극적이며 글로벌 정책을 주도하고 있다. 2014년 OPM(인사관리처)의 대규모 정보 유출 사고를 겪은 이후 미 하원은 약 2년간의 조사와 원인을 분석 하였고 감독개혁위원회 보고서를 통해 연방정부의 보안 강화를 위한 제로트러스트 도입을 권고했으며 이후 NIST(국립표준기술연구소)는 2020년 SP 800-207 문서를 통해 제로트러스트 아키텍처를 최초로 정의했다. 2021년 바이든 행정부 출범 이후 고도화되는 사이버 위협은 기존 사이버 보안 체계로 대응할 수 없다는 판단하에 2021년 5월, ‘국가 사이버 보안 개선을 위한 행정 명령(Executive Order 14028 - Improving the Nation’s Cybersecurity)’을 발표하면서 연방민간행정기관(FCEB) 전체의 제로트러스트 아키텍처의 도입을 명시하고 공식화하였다. 또한,

연방정부 차원에서 제로트러스트 구현을 현실화하기 위한 다양한 프로젝트를 진행해 오고 있다. NIST의 국가사이버보안센터(NCCoE)에서는 주요 보안 기업들과 함께 제로트러스트 아키텍처 구현 프로젝트를 통한 실증을 진행하고 그 결과로 2023년 7~9월 NIST SP 1800-35 시리즈 문서의 3rd Preliminary Draft를 발간하였으며 2024년 7월 시리즈 문서를 모두 통합한 4th Preliminary Draft를 발간하기도 하였다.

미 국방부(DoD)와 국가안보국(NSA)은 2022년 발표했던 제로트러스트 참조 아키텍처 2.0 및 제로트러스트 전략, 역량 실행 로드맵 이후 이를 뒷받침하는 제로트러스트 핵심 요소 7가지에 대한 성숙도 문서를 2023년 4월부터 2024년 7월까지 발간하였다. 또한 2024년 제로트러스트 오버레이 문서를 발간하여, 제로트러스트 핵심 요소, 제로트러스트 구현 활동과 NIST SP 800-53과의 관련성을 분석하였다. 이는 각 연방 기관들이 제로트러스트 아키텍처를 도입하는 데 있어 단순히 특정 기능만을 도입하라는 것이 아니라, 기관 성격에 맞는 다양한 가이드 문서들을 발간함으로써 각 기관이 자율적이면서도 정부의 일관된 원칙하에 제로트러스트 아키텍처를 구축하고 솔루션을 도입할 수 있는 체계를 구성함과 동시에 사례를 지속 확보·수집하고 있다.

각 연방 기관들은 관리예산실(OMB)이 제시한 일정에 따라 각 기관이 세운 2024년 9월까지의 계획하에 OMB 각서를 참고하여 제로트러스트 아키텍처를 도입해 왔으며, 최근 Mike Duffy 연방 CISO 대행은 최근 인터뷰에서 각 기관들의 제로트러스트 구현에 대해 엄청난 진전이 있었음을 공개했다. 미 국방부 역시 Thunderdome 프로젝트를 통하여 국방부 및 산하 기관 등과 SASE 중심의 제로트러스트 아키텍처를 도입하여 사용 중이다. 이처럼 미국은 연방정부에서 실질적으로 활용할 수 있는 많은 가이드 및 관련 문서 발간을 통해 각 기관이 제로트러스트를 도입하는 관점에서 폭 넓은 시야와 전략을 제공하고 있다.

표 1-1 제로트러스트 관련 미 연방정부 주요 정책 대응 현황

시기	기관	주요 문서 및 발간 자료
2023.07~09	NIST	'제로트러스트 아키텍처 구현 (SP 1800-35A~E, 3rd Preliminary Draft)' 발간
2023.09	NIST	'다중 클라우드 환경 상의 클라우드 네이티브 응용에서 접근제어를 위한 제로트러스트 아키텍처 모델 (SP 800-207A)' 발간
2023.10	DHS	'제로트러스트 구현 전략' 발간
2023.10	NSA	'기기 핵심 요소를 통한 제로트러스트 성숙도 개선' 발간
2024.02	DoD	'제로트러스트 오버레이 v1.0' 발간
2024.02	GSA	'제로트러스트 아키텍처 - 구매자 가이드 3.1' 발간
2024.03	NSA	'네트워크 및 환경 핵심 요소를 통한 제로트러스트 성숙도 개선' 발간
2024.04	GAO	'사이버 보안 - 주요 조치를 해결하기 위해서는 행정명령 요구사항 이행이 필수적' 발간
2024.04	NSA	'데이터 핵심 요소를 통한 제로트러스트 성숙도 개선' 발간
2024.05	NSA	'애플리케이션 및 워크로드 핵심 요소를 통한 제로트러스트 성숙도 개선' 발간
2024.05	NSA	'가시성 및 분석 핵심 요소를 통한 제로트러스트 성숙도 개선' 발간
2024.06	CISA 등	'네트워크 접근 보안에 대한 최신 접근방식' 발간
2024.06	DoD	'제로트러스트 오버레이 v1.1' 발간
2024.07	NIST	'제로트러스트 아키텍처 구현 (SP 1800-35, 4th Preliminary Draft)' 발간
2024.07	NSA	'자동화 및 통합 핵심 요소를 통한 제로트러스트 성숙도 개선' 발간
2024.08	GSA	'제로트러스트 전략 구매자 가이드 1.3 - DoD 제로트러스트 전략' 발간
2024.08	CISA	'연결된 커뮤니티 가이드선: 상호 연결된 시스템을 보호하기 위한 제로트러스트' 발간
2024.09	OMB	M-22-09 각서에서 요구한 연방 기관 제로트러스트 도입 일정 종료

제로트러스트 도입을 통한 보안 체계의 전환은 비단 미국 연방정부 시스템에만 국한되지 않는다. 물론 미국처럼 구체적으로 적용 단계는 아니지만 영국, 일본, 싱가포르, 캐나다, 중국 등 글로벌 각국 정부 역시 제로트러스트 보안 체계 전환의 필요성을 공감하고 가이드·전략 발표 등 다양한 정책적 움직임을 보이고 있다.

3. 가이드라인 2.0 추진 경과

2023년 7월 과학기술정보통신부와 한국인터넷진흥원, 한국제로트러스트포럼이 공동으로 ‘제로트러스트 가이드라인 1.0’(이하, 가이드라인 1.0)을 발간한 바 있다. 가이드라인 1.0은 제로트러스트 아키텍처의 도입을 검토하고 있는 기업들의 보안 전략 수립 책임자 및 실무자에게 제로트러스트의 기본 개념 및 원리, 보안 모델 등을 정의하고, 도입 절차와 구현 유스케이스를 상위 수준에서 기술함으로써 각 기업 환경에 적합한 도입 로드맵과 전략을 구성하는 데 도움을 주려는 목적으로 발간되었다.

가이드라인 집필진은 가이드라인 1.0 발간 이후 정부 부처, 관계 기관, 수많은 기업 담당자로부터 다양한 피드백을 받았다. 우리나라에서 실질적으로 처음 발행된 제로트러스트에 대한 가이드라인이다 보니 많은 분야에서 관심을 가지고 다양하게 인용됐으며 제로트러스트에 대한 이해를 한층 높일 수 있었고 조직 차원에서 제로트러스트 아키텍처를 도입해야 할 필요성에 대한 인식을 확산하고 공감하는데 좋은 기본서가 됐다는 긍정적인 평이 많았다.

하지만 가이드라인 1.0은 제로트러스트에 대한 개념을 정의하는 등의 상위 수준에서 기술할 수밖에 없는 태생적 한계가 있었다. 그 이유는 기업마다 망 구조와 보안 아키텍처의 구성이 전부 다르고 실증 결과를 반영할 수 없었기에 구체적인 도입 사례나 방법론을 담을 수 없었기 때문이다. 따라서 제로트러스트를 해당 기업망에 실제로 도입하기 위한 의사 결정이나 구체적 계획을 잡기 위해서 도입 과정을 구체화하는 형태로 문서 수준을 높이고 도입 관점의 전략을 세울 수 있도록 가이드라인의 구체화를 희망하는 요구가 꾸준히 있어 왔다.

제로트러스트는 ‘절대 신뢰하지 말고, 항상 검증하라(Never Trust, Always Verify)’는 새로운 보안 철학이자 개념으로, 도입 과정에서 제로트러스트의 원리를 최대한 준수하는 것이 핵심이다. 이 과정에서 특정 보안 기술이나 솔루션을 강제하지 않으며, 기업의 보안 담당자들은 기존 기업망 구조와 레거시 보안 방식, 보안 목표 등을 고려하여 도입 전략을 수립해야 한다. 하지만 아직까지는 실 환경에서 제로트러스트 아키텍처 도입·운용 사례가 거의 없어 도입에 대한 효과를 분석하기 어려운 상황이며, 보안 담당자들은 어떤 기술·솔루션을 선택하고 도입 계획을 수립해야 할지 어려움을 겪고 있다. 따라서, 본 문서의 집필진은 가이드라인 1.0의 부족한 점을 보완하고 주요기업 보안 담당자들의 어려움을 고려하여 제로트러스트 도입 과정을 보다 구체화하고 도입 수준을 분석할

수 있는 방안을 제시함으로써 각 기업들의 제로트러스트 아키텍처 도입을 가속화하는 데 도움을 주고자 가이드라인 2.0 발간을 계획하게 되었다.

본 가이드라인 2.0의 발간을 위하여 과학기술정보통신부와 한국인터넷진흥원 및 한국제로트러스트 포럼 정책·제도분과 소속 산학연관 전문가들을 중심으로 2024년 5월 제로트러스트 가이드라인 연구반을 구성하였다. 이후 연구반 위원들이 함께 가이드라인 2.0 구성 및 초안 작성을 진행했으며, 2024년 6월 첫 회의를 시작으로 약 5개월간 5차례 공식 회의, 별도 비공식 온라인 회의, 집필진 간 개별 토론 및 수정 작업 등 열띤 협의 과정을 거쳐 2024년 11월 최종적으로 본 가이드라인 2.0을 발간하게 되었다.

특히 집필진들이 모여 발간 계획을 논의하는 과정에서 제로트러스트 도입 과정을 구체화하고자 하는 작성 방향이 단순히 기존 가이드라인 1.0의 업데이트만으로 해결할 수 없다는 공통의 인식하에, 성숙도 모델의 구체화, 수요기업의 도입 준비 방안 제시, 도입 이후 효과성 분석 방안 제시 등 기존 가이드라인에 없던 새로운 내용을 반영하는 것에 초점을 맞추었다. 집필 초기부터 이러한 작성 방향이 수요기업에게 현실적으로 훨씬 도움이 될 것이라는 철학을 집필진들 사이에 공유하고 있었기 때문에, 가이드라인 1.0을 단순히 업데이트하는 것이 아닌 별도 문서 형태로 가이드라인 2.0을 작성하게 되었다.

정부는 향후 산업 도메인이나 시나리오별 참조 아키텍처, 제로트러스트 관점이 적용된 보안 통제 혹은 인증 기준 등 다양한 제로트러스트 가이드 문서를 추가 개발하는 것도 고려하고 있으며, 이에 관한 많은 의견과 제안이 있기를 기대한다.

| 제2절 |

가이드라인 2.0 목적 및 구성

앞서 언급한 바와 같이, 기업 소속의 보안 담당자들이 가이드라인 1.0을 참고하여 제로트러스트 아키텍처를 도입하는 과정에서의 어려움을 조금이라도 해소할 수 있도록, 제로트러스트 도입 시 반드시 고려해야 할 사항 및 도입 준비 방안, 그리고 도입 이후 제로트러스트 수준 분석 방안을 본 문서에서 제안하고자 한다.

기업들은 기업의 규모, 적용받는 관련 규정, 보안에 투자할 수 있는 비용, 현재 활용 중인 디지털 자산과 이용하는 서비스의 종류 등이 모두 다를 수 있다. 기존의 망 분리 조치를 계속 유지해야 하는가에 대한 고민, 클라우드 서비스의 활용 관점에서의 보안 전략 고민 등이 있을 수 있으며 랜섬웨어 등 이미 특정 공격에 피해를 입은 경험을 바탕으로 고도화된 위협에 대응할 수 있는 새로운 보안 구조를 만들고 싶을 수도 있을 것이다.

이러한 다양한 상황과 관점에 비추어, 제로트러스트 보안 구조를 상세히 규정하는 것은 적절하지 않으며 본 가이드라인의 목적과 맞지 않는다. 본 가이드라인 2.0의 목적은, 보안 담당자들의 제로트러스트 도입 전략 수립 과정에서 반드시 검토해야 할 사항을 강조함으로써 도입 전략 수립을 지원하고, 도입 후 보안 수준 및 효과성 분석 방안을 제안함으로써 보안 모델을 어떻게 지속적으로 개선해 나갈 수 있을지에 대한 방향성 설정에 도움을 주기 위함이다.

상기 목적을 위하여 본 문서는 다음과 같이 구성하였다.

먼저, 2장에서는 제로트러스트 아키텍처에 대해 간략히 소개하고자 한다. 즉, 제로트러스트 아키텍처 및 용어에 대한 정의, 보안 모델 및 기본 원리와 함께 기업이 제로트러스트 아키텍처를 도입해야 하는 이유를 다루었다.

3장은 제로트러스트 성숙도 모델 및 세부역량³을 다루고 있으며, 제로트러스트 도입을 위해 반드시 고려해야 할 성숙도 모델에 대해 그 의미와 역할 활용 방안에 대해 소개한 후, 구체적인 성숙도 모델을 제시한다. 가이드라인 1.0에서의 3단계 성숙도에서 ‘초기’ 단계를 추가하고, 각 단계에서 요구하는 기능을 보완하였으며, 특히 이에 대한 기술 도입을 고려한 보안 세부역량까지 제시하였다. 이를 통해 각 기업들이 제로트러스트 아키텍처를 설계하려고 할 때 어떤 보안 역량이 필요한지를 참고할 수 있을 것으로 보인다.

4장은 제로트러스트 도입 준비 방안을 다룬다. 먼저 제로트러스트 아키텍처를 도입할 경우 반드시 고려해야 하는 여러 관점을 소개하고, 제로트러스트 도입을 위한 조직 구성 및 목표 설정, 기업의 제로트러스트 아키텍처 구성 방안(현재 기업망 분석과 제로트러스트 아키텍처 정의 등)을 다루었으며, 개발망에 대한 예시를 통하여 이해를 도울 수 있도록 하였다.

5장은 제로트러스트 도입 이후 효과성을 분석하는 데 도움을 줄 수 있는 내용을 포함한다. 즉, 제로트러스트 성숙도를 기반으로 자체 보안 수준을 평가함으로써 보안 성숙도 고도화에 참고할 수 있는 분석 방안을 제시하였으며, 제로트러스트 아키텍처 도입에 대한 침투 시험을 기반으로 효과성을 분석할 수 있는 방안도 함께 제시한다.

이 외에 부록에서는 가이드라인 2.0의 이해를 돕기 위하여, 보안 기술 및 솔루션 관련 용어 소개, 국내 기업의 제로트러스트 인식 수준, 2023년 과학기술정보통신부에서 수행한 제로트러스트 실증 사업을 통한 제로트러스트 아키텍처 참조 모델 사례 제시, 미 연방정부 제로트러스트 도입·실증 현황(NIST 제로트러스트 아키텍처 구현 프로젝트, 미 국방부 Thunderdome 프로젝트), 성숙도 모델에 대한 기초 개념, ISMS-P 인증기준과 제로트러스트 성숙도 모델 연계, 참고 문헌 등을 기술하였다.

〈표 1-2〉는 기업 구성원 역할에 따라 반드시 읽기를 권장하는 항목을 정리하였다.

3 부록 1절에서 세부역량을 ‘일련의 작업을 수행하기 위한 수단과 방법의 조합을 통해 원하는 요구사항 혹은 효과를 달성할 수 있는 능력 및 능력을 바탕으로 구현되는 구체적 기능’으로 정의내리고 있다. 세부역량에 대해서는 소프트웨어·하드웨어 구현까지 고려하여 구체적으로 정의를 내리는 것이 적절하며, 이렇게 구체적인 정의 과정을 통하여 CISA 등 기존 성숙도 모델의 기능이 추상적으로 정의가 되어있는 한계를 보완할 수 있다. 본 가이드라인 3장에서는 제로트러스트 기능 정의와 함께 도입·구현 과정에서 참고할 수 있도록 기능의 하위 개념으로 세부역량을 정의하였다.

표 1-2 기업 구성원별 필독 항목

기업 구성원	본 가이드라인의 필독 항목
최고경영자 (CEO)	▶ 제1장 제로트러스트 가이드라인 2.0 개요 8P ▶ 제2장 제2절 기업은 왜 제로트러스트를 도입해야 하는가? 28P ▶ 제4장 제2절 제로트러스트 아키텍처 도입을 위한 조직 내 역할 및 목표 설정 120P
정보보호 최고책임자 (CISO)	▶ 제1장 제로트러스트 가이드라인 2.0 개요 8P ▶ 제2장 제로트러스트 보안 모델 및 도입 필요성 22P ▶ 제3장 제1절 제로트러스트 성숙도 모델 2.0 35P ▶ 제3장 제2절 제로트러스트 성숙도 모델 기반 보안 세부역량 51P ▶ 제4장 제1절 제로트러스트 도입 고려사항 106P ▶ 제4장 제2절 제로트러스트 아키텍처 도입을 위한 조직 내 역할 및 목표 설정 120P ▶ 제5장 제1절 제로트러스트 성숙도 기반 도입 수준 분석 150P
정보보호관리자 및 담당자	▶ 문서 전반에 걸친 이해 필요 ▶ 제3장 제로트러스트 성숙도 모델 및 세부역량 35P ▶ 제4장 제로트러스트 도입 준비 방안 106P ▶ 제5장 제로트러스트 도입 수준 분석 150P



| 제3절 |

가이드라인 2.0 주안점

본 가이드라인 2.0은 가이드라인 1.0과 비교하여 다음에 주안점을 두고 작성하였다.

첫째, 제로트러스트 성숙도 모델을 더욱 구체화하였다. 3장에서는 제로트러스트 보안 모델 도입의 수준을 판단할 수 있는 성숙도 모델을 세분화하여 한국형 성숙도 모델을 정립하고자 하였으며, 성숙도 모델에서 요구하는 보안 기능 및 세부역량 구체화를 통하여 제로트러스트 도입을 희망하는 기업의 실질적인 도입 전략 수립을 지원하고자 하였다. 성숙도 모델 2.0에서는 성숙도 수준 ‘초기’ 단계를 추가하여 가이드라인 1.0의 성숙도 수준인 기준, 향상, 최적화 3단계에서 기준, 초기, 향상, 최적화의 4단계로 늘어나고, 각 단계별 특징을 보다 구체화된 형태로 포함하고 있다. 특히 3.2절에서는 6가지 핵심 요소 및 2가지 교차기능에 대한 52가지 보안 세부역량, 세부역량의 성숙도 수준별 특징을 정의하여 현재 기업망의 수준을 평가할 때 그리고 실제 제로트러스트 기술·솔루션을 도입하고자 할 때 고려해야 하는 기능을 최대한 다룰 수 있도록 하였다.

둘째, 제로트러스트 도입 절차를 구체화하였다. 4장에서는 먼저 제로트러스트 아키텍처의 도입 과정에서의 고려 사항을 정리함으로써 수요기업들이 제로트러스트에 대하여 정확한 개념을 인식할 수 있도록 돕고 있으며, 제로트러스트를 실제 도입할 기업이 제로트러스트 아키텍처를 도입하기 위한 조직 내 역할(기업 내 임직원 간 역할과 책임, 각 구성원의 역할) 및 목표 설정 방안을 제안하였다. 3절에서는 제로트러스트 아키텍처를 처음 도입하는 기업들이 준비 단계로 진입하기 전부터 준비 단계에 이르기까지 진행해야 하는 업무를 구체화하여 다루었으며, 4절에서는 도입을 준비하는 과정에서 어떤 일들을 하게 되는지 예시를 통해 기술하였다.

셋째, 제로트러스트 아키텍처를 도입한 기업이 자사 기업망에 도입한 제로트러스트의 수준 혹은 효과성을 분석할 수 있는 방안을 제시하였다. 5장에서 성숙도 기반의 체크리스트 수준 분석, 모의 침투시험 효과성 분석과의 연계 등을 통하여 제로트러스트 아키텍처의 도입 수준과 효과를

분석하는 방안을 제시함으로써, 보안 수준의 향상 정도를 도입 기업이 자체적으로 판단할 수 있도록 하였다.

표 1-3 본 문서와 가이드라인 1.0 비교

주요 내용	가이드라인 1.0	본 문서 작성·추가 사항
제로트러스트 성숙도 모델	▶ <u>3단계 성숙도 수준</u> 정의 ▶ <u>기업망 핵심 요소별 20가지 기능</u> 정의 (교차 기능 제외)	▶ ‘초기’ 단계를 추가한 <u>4단계 성숙도 수준</u> 정의 ▶ <u>기업망 핵심 요소별 27가지 기능</u> 정의 (교차 기능 제외) 및 각 단계별 특징 구체화 ▶ 기업망 핵심 요소 및 2가지 교차 기능에 대한 <u>52가지 보안 세부역량 및 각 세부역량의 성숙도 수준별 특징</u> 정의 ▶ 성숙도 모델에 기반한 구현 방안 제시
제로트러스트 도입 절차	▶ 제로트러스트 아키텍처 <u>도입 고려사항 정리</u> (성숙도 모델 관점 및 기업 내외부 환경 관점) ▶ 총 <u>5단계의 제로트러스트 아키텍처 도입 단계 제시</u> (준비 → 계획 → 구현 → 운영 → 피드백 및 개선) ▶ OMB 각서를 참고하여 제로트러스트 구현에 따르는 <u>핵심 요소별 초기 전략 제시</u>	▶ 제로트러스트 아키텍처 <u>도입 과정에서의 고려사항 구체화</u> (제로트러스트에 대한 명확한 이해 및 기업 내 인식 제고 등 추가) ▶ <u>제로트러스트 도입 준비 단계 구체화</u> (업무 구체적 기술 및 예시 제시) ▶ 제로트러스트 아키텍처 도입을 위한 <u>조직 내 역할 및 목표 설정 방안</u> 제시
기타	▶ <u>제로트러스트 구현에 관한 6가지 유스케이스</u> 및 목표·요구사항, 구현 방안 등 제시 ▶ 제로트러스트 도입 후 <u>보안 수준 평가 방안 없음</u>	▶ 제로트러스트 <u>도입 후 기업망 보안 수준을 평가할 수 있는 2가지 방안</u> 제시 (성숙도 기반 도입 수준 분석을 위한 체크리스트, 침투시험 기반 제로트러스트 효과성 분석 방안) ▶ 부록에서 2023년도 <u>제로트러스트 실증 사례 소개</u>

